

A photograph of a modern university building with large glass windows and a white facade. In the foreground, there is a field of tall, dry grass and many small yellow flowers. The sky is blue with a few white clouds.

5CM512

Communication and Security Protocols

Week 7 : Intruders

CLASS DISCUSSION

- What is intruder?
- How can a user become an intruder?
- What are examples of software trespass?
- How can software intruder be introduced to system?

Intruders

- Three classes of intruders:

Masquerader

- An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account



Misfeator

- A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges



Clandestine user

- An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection



Class exercise

- Discuss how someone can intrude to our systems.
- Discuss and list some examples of intrusion

Examples of Intrusion

- Performing a remote root compromise of an e-mail server
- Defacing a Web server
- Guessing and cracking passwords
- Copying a database containing credit card numbers
- Viewing sensitive data, including payroll records and medical information, without authorization
- Running a packet sniffer on a workstation to capture usernames and passwords
- Using a permission error on an anonymous FTP server to distribute pirated software and music files
- Dialing into an unsecured modem and gaining internal network access
- Posing as an executive, calling the help desk, resetting the executive's e-mail password, and learning the new password
- Using an unattended, logged-in workstation without permission

Hackers

- For the thrill of it or for status
- Intrusion detection systems (IDSs) and intrusion prevention systems (IPSs)
 - Counter hacker threats
 - In addition
 - restricting remote logons to specific IP addresses
 - use virtual private network technology
- CERTs
 - Computer emergency response teams
 - Collect information about system vulnerabilities and disseminate it to systems managers
 - Hackers also routinely read CERT reports
 - It is important for system administrators to quickly insert all software patches to discovered vulnerabilities



Kevin David Mitnick

https://en.wikipedia.org/wiki/Kevin_Mitnick

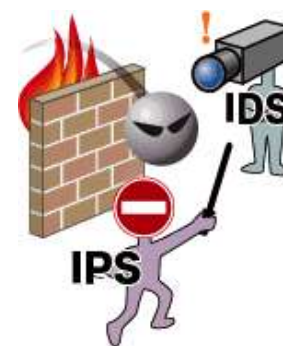


AFTER Class exercise

- Visit UK CERT website after class
- <http://www.ukcert.org.uk/>
- <https://www.ncsc.gov.uk/section/keep-up-to-date/cisp>
- Visit the tabs and the links in the main web site

Criminal hackers

- Organized groups of hackers
- Usually have specific targets, or at least classes of targets in mind
- Once a site is penetrated, the attacker acts quickly, scooping up as much valuable information as possible and exiting
- IDSs and IPSs can be used for these types of attackers,
 - but may be less effective because of the quick in-and-out nature of the attack



Class Exercise

- What the basic technology do we use for IPS?
- Password based protection

Password Guessing



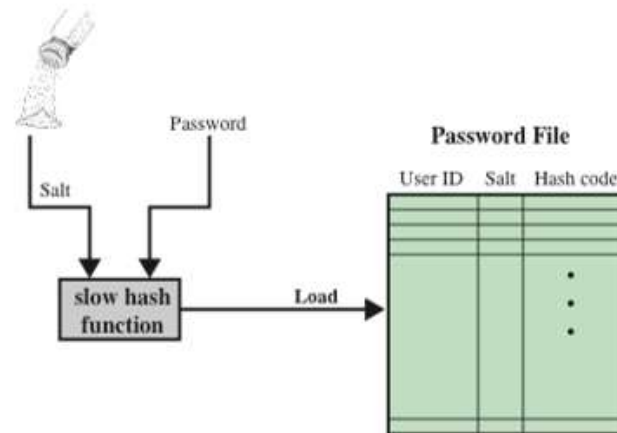
1. Try default passwords used with standard accounts that are shipped with the system. Many administrators do not bother to change these defaults.
2. Exhaustively try all short passwords.
3. Try words in the system's online dictionary or a list of likely passwords. Examples of the latter are readily available on hacker bulletin boards.
4. Collect information about users, such as their full names, the names of their spouse and children, pictures in their office, and books in their office that are related to hobbies.
5. Try users' phone numbers, Social Security numbers, and room numbers.
6. Try all legitimate license plate numbers for this country.
7. Use a Trojan horse to bypass restrictions on access.
8. Tap the line between a remote user and the host system.
9. Use Social Science or Phishing emails.

Password Management

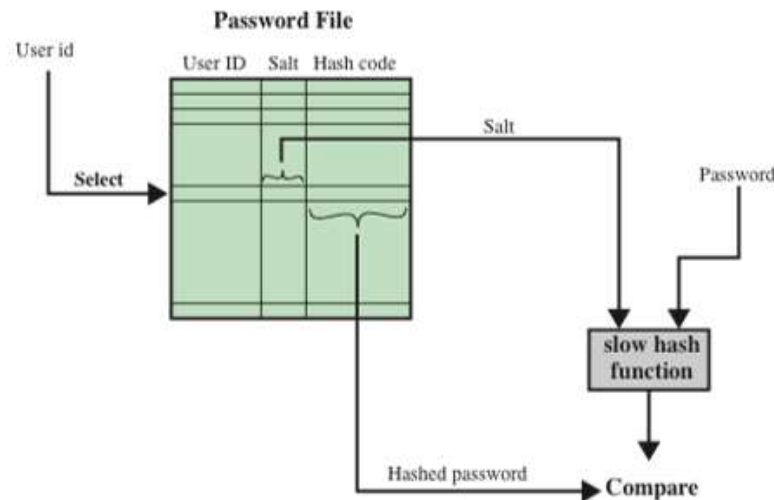


- Front line of defense against intruders
- Virtually all multiuser systems require that a user provide not only a name or identifier (ID) but also a password
 - Password serves to authenticate the ID of the individual logging on to the system
 - The ID provides security by:
 - Determining whether the user is authorized to gain access to a system
 - Determining the privileges accorded to the user
 - Used in discretionary access control

UNIX PASSWORD SCHEME



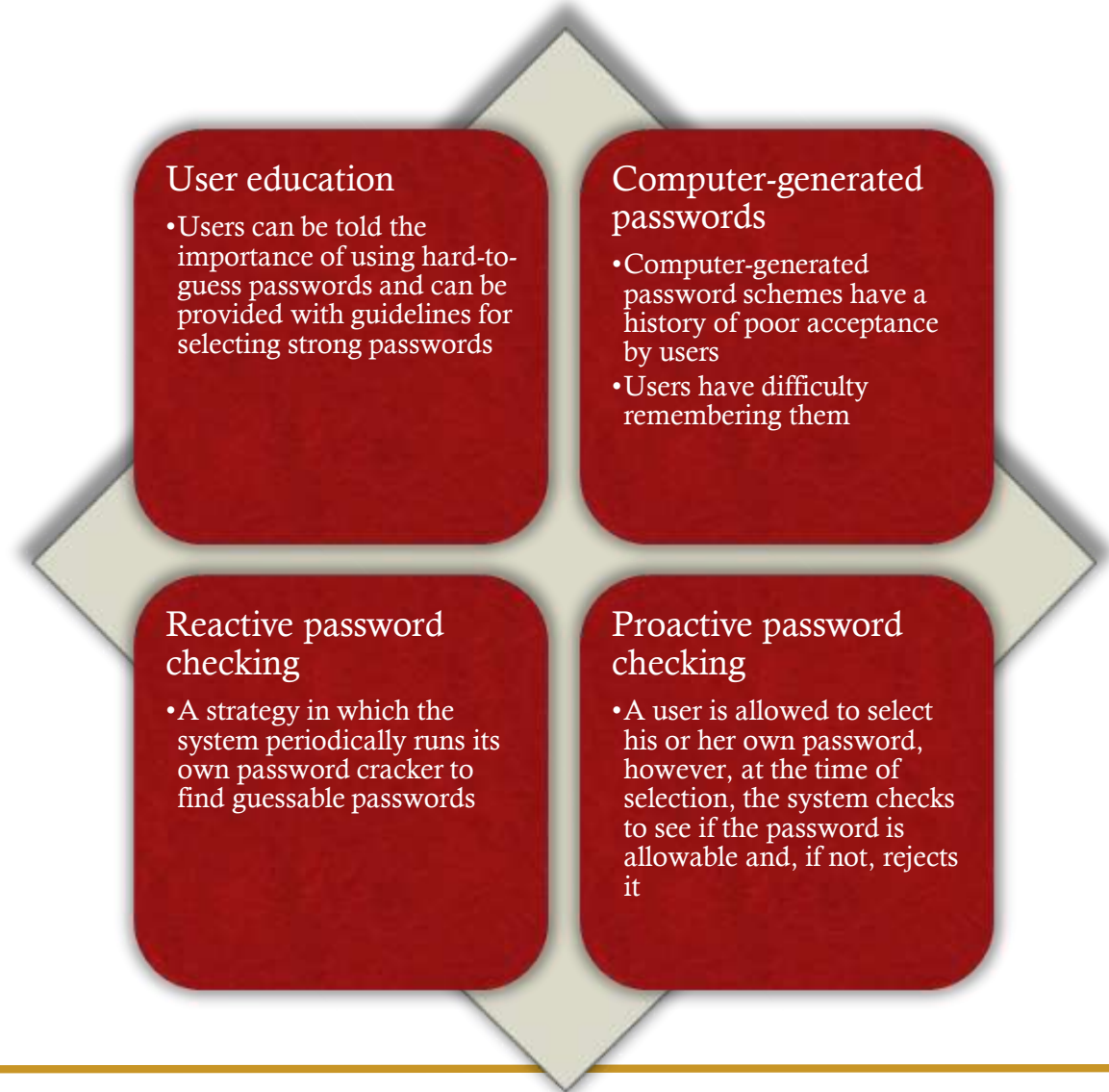
(a) Loading a new password



(b) Verifying a password

Password selection strategies

- The goal is to eliminate guessable passwords while allowing the user to select a password that is memorable
- Four basic techniques are in use:

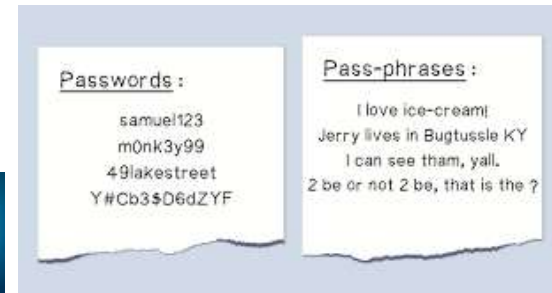


Multi-factor authentication

- Grant access only after successfully presenting two or more pieces of evidence



- Knowledge
 - something only the user knows



- Possession
 - something only the user has



- Inherence
 - something only the user is



- A third-party authenticator (TPA) app



Insider Attacks

- Among the most difficult to detect and prevent



- Can be motivated by revenge or simply a feeling of entitlement



Class exercise

- Discuss possible countermeasures against insider attacks



Any QUESTIONS?

